

Roles and Responsibilities

DOCUMENT CLASSIFICATION	Internal
VERSION	1.0
DATED	July 16, 2026
DOCUMENT AUTHOR	Aman Verasinghani
DOCUMENT OWNER	ABZ Technologies

Revision history

Version	Date	Revision Author	Summary
1.0	16/07/2026	Aman Verasinghani	Initial Draft

Distribution

Name	Title
Deepti	CEO
Abhishar	CIO
Rd	CTO

Approval

Name	Position	Signature	Date
Deepti	CEO	Signed:	16/07/2026
Abhishar	CIO	Signed:	18/07/2026
RD	CTO	Signed:	20/07/2026

Contents

Purpose	4
Scope	4
Roles and Responsibilities	4
Authority and Accountability	7
Competence and Training	7
Review of Roles and Responsibilities	7
Document Control	8

Purpose

The purpose of this document is to define and assign roles and responsibilities for information security management in accordance with the requirements of the ISO/IEC 27001:2022 standard. It ensures that all employees understand their roles in maintaining and improving the Information Security Management System (ISMS).

Scope

This document applies to all employees, contractors, and third parties who have access to or manage information within **ABZ Technologies**. It covers all information security activities within the ISMS scope.

Roles and Responsibilities

3.1 Top Management (CEO, Board of Directors)

Responsibilities:

- Provide leadership and demonstrate commitment to the ISMS.
- Approve the Information Security Policy.
- Ensure that sufficient resources are allocated to the ISMS.
- Review ISMS performance and take action to ensure continual improvement.

Why it's required: *Clause 5.1 requires top management to demonstrate leadership and commitment. Auditors will verify that leadership is actively involved in the ISMS.*

3.2 Information Security Manager (ISMS Manager)

Responsibilities:

- Oversee the development, implementation, and maintenance of the ISMS.
- Coordinate risk assessments and ensure risk treatment plans are implemented.
- Ensure compliance with the ISO 27001 standard and other applicable regulations.
- Monitor and report on the effectiveness of the ISMS to top management.
- Lead information security awareness and training programs.
- Act as the point of contact during external audits.

Why it's required: Clause 5.3 requires specific roles and responsibilities to be assigned. The ISMS Manager is crucial for day-to-day operations and for maintaining ISO 27001 compliance.

3.3 Risk Officer

Responsibilities:

- Identify and assess information security risks.
- Maintain the risk register and ensure risk assessments are conducted periodically.
- Develop and maintain risk treatment plans.
- Report risk management activities to the ISMS Manager and top management.

Why it's required: Clause 6.1.2 requires an established risk assessment and treatment process. The Risk Officer ensures that this process is managed effectively.

3.4 IT Manager

Responsibilities:

- Implement technical controls (e.g., firewalls, encryption) as defined in the risk treatment plan.
- Ensure that the organization's IT infrastructure complies with the ISMS policies and procedures.
- Monitor and maintain the security of the organization's networks, systems, and applications.
- Coordinate with the ISMS Manager to respond to and resolve security incidents.

Why it's required: Technical controls (referenced in Annex A of ISO 27001) must be implemented and monitored. The IT Manager plays a crucial role in maintaining the technological security of the organization.

3.5 HR Manager

Responsibilities:

- Ensure information security roles and responsibilities are included in job descriptions.
- Conduct background checks and screening for new hires as part of the hiring process.
- Ensure that personnel are aware of their information security responsibilities through training and onboarding.
- Coordinate with the ISMS Manager for information security awareness programs.

Why it's required: Annex A, A.7.1.1 (Screening) and Clause 7.2 require that employees be competent and aware of their responsibilities. The HR Manager ensures that the people managing information are properly vetted and trained.

3.6 Department Heads

Responsibilities:

- Ensure that information security policies and procedures are followed within their departments.
- Identify departmental risks and report them to the Risk Officer or ISMS Manager.
- Monitor departmental compliance with the ISMS and report any incidents or vulnerabilities.

Why it's required: Department Heads must ensure that security is implemented at every level. This supports Clause 5.3 by ensuring that everyone in the organization is aligned with ISMS goals.

3.7 All Employees

Responsibilities:

- Comply with the Information Security Policy and all related procedures.
- Report information security incidents or suspected weaknesses to the ISMS Manager or IT Manager.
- Protect the confidentiality, integrity, and availability of information as part of their daily work.

Why it's required: Employees play a key role in maintaining security. Clause 7.3 requires that all employees are aware of the importance of information security and how to protect it in their daily activities.

Authority and Accountability

Each individual listed above is accountable for the roles and responsibilities assigned to them. They are authorized to carry out the necessary tasks to support the effective implementation and maintenance of the ISMS.

Competence and Training

- **Training Requirements:**

- All personnel involved in managing and maintaining the ISMS must receive appropriate training and certification (if necessary) to ensure competence in their roles.

- **Frequency of Training:**

- Regular refresher courses and training sessions will be held annually to ensure that staff are aware of the latest security practices and their evolving responsibilities.

Why it's required: *Clause 7.2 requires that personnel have the necessary competence to perform their roles. Auditors will check if staff are adequately trained to manage information security risks.*

Review of Roles and Responsibilities

- The roles and responsibilities outlined in this document will be reviewed annually or in the event of significant changes to the organizational structure or ISMS requirements.

Why it's required: *Clause 9.3 (Management Review) requires that roles and responsibilities are regularly reviewed to ensure they remain relevant and effective.*

Document Control

- This document is controlled under the ISMS document management system and will be reviewed and updated as required.

Why it's required:

- All documents in the ISMS, including the roles and responsibilities, must be version-controlled and reviewed periodically per Clause 7.5.